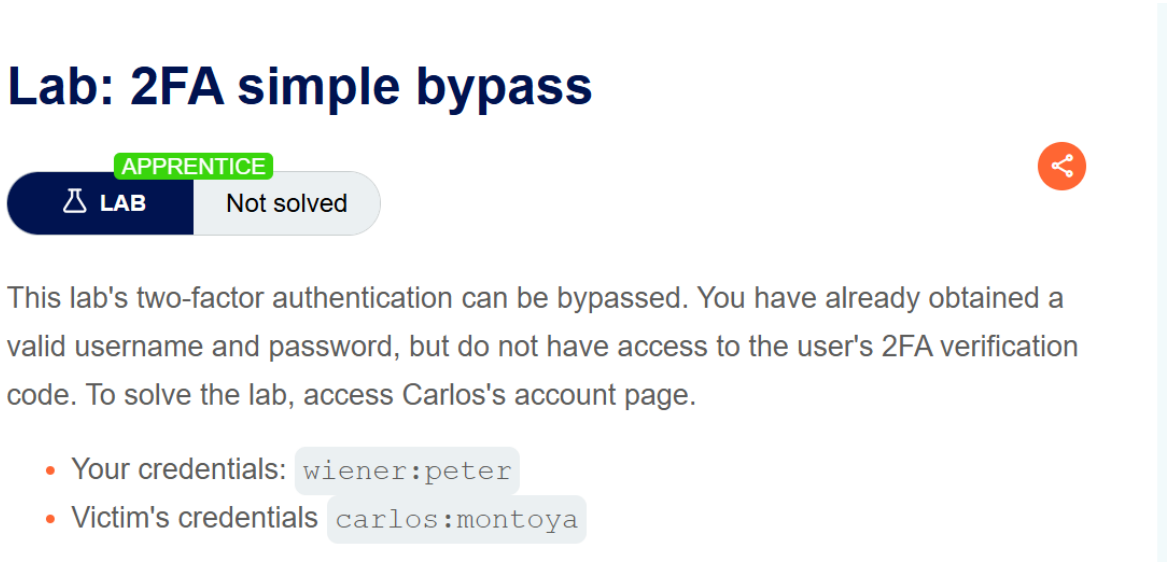
Day 33 – Multi-Factor Authentication Security

PLATFORM

PortSwigger Web Security Academy — Official Lab: 2FA simple bypass

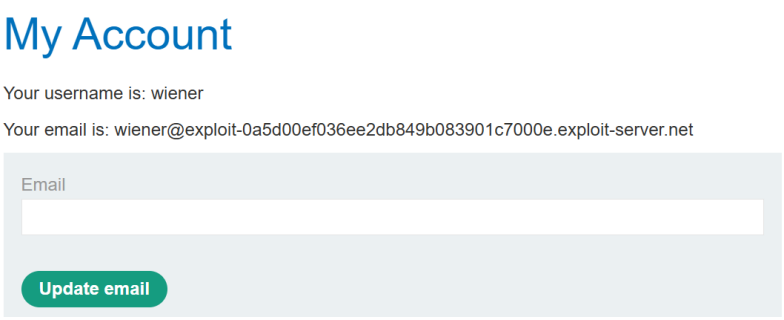
https://portswigger.net/web-security/authentication/multi-factor/lab-2fa-simple-bypass



STEPS

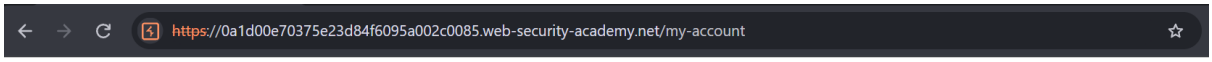
1. Launch the provided lab.

2. Log in using the training credentials supplied by the lab.



3. Observe the normal MFA workflow.

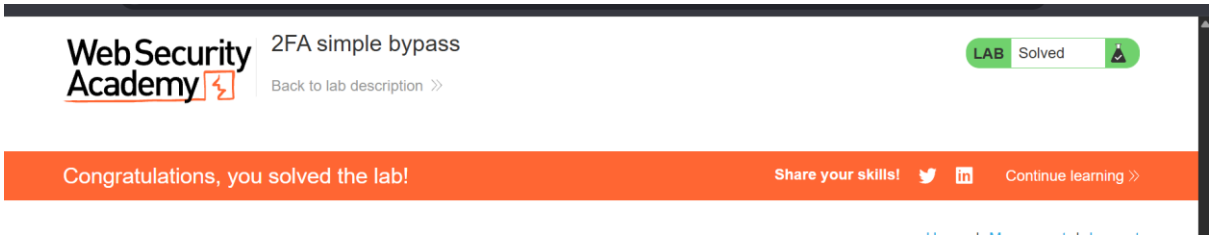
4. Identify the account page URL in the training environment.



5. Understand how the intentionally vulnerable application handles authentication state.

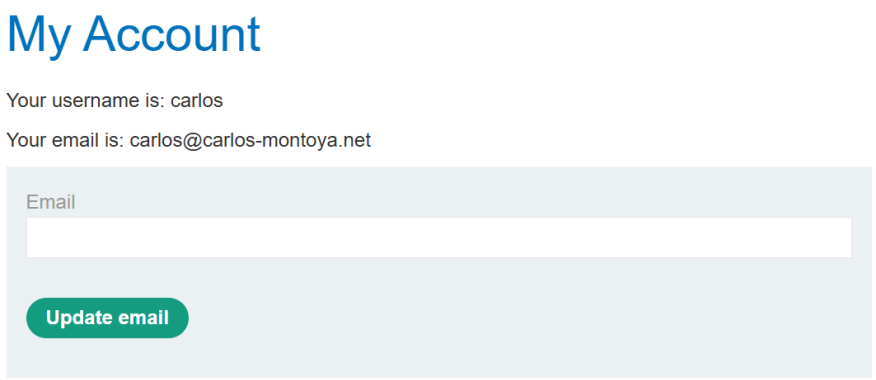
6. Complete the official training exercise.

Day 33 – Multi-Factor Authentication Security



7. Record screenshots demonstrating: lab environment, MFA step, account/session behavior, successful lab completion.





ANALYSIS QUESTIONS

1. What was the security weakness?

The application had an MFA bypass vulnerability because it allowed access to the victim's account page without completing the second authentication step.

2. Why was MFA not effectively enforced?

The application did not properly verify whether the user had completed MFA before granting access to protected account pages. Changing the URL from the login page to /my-account allowed access without completing the security-key verification.

3. Which security decision should have been enforced server-side?

The server should verify that the user has successfully completed both password authentication and MFA verification before granting access to protected pages.

4. Why is frontend-only MFA enforcement unsafe?

- Users can modify URLs and navigate directly to protected pages.

Day 33 – Multi-Factor Authentication Security

- Frontend checks can be bypassed because users have control over browser-side navigation.
- The server must independently verify authentication status before allowing access to sensitive resources.

5. Give at least four recommended mitigations.

- Server-side MFA verification: Verify MFA completion on the server before granting access.
- Secure session management: Maintain separate authentication states for password verification and completed MFA.
- Access control: Protect account pages and sensitive endpoints against unauthorized access.
- Session restriction: Do not grant full account permissions until MFA is successfully completed.
- Session expiration: Expire incomplete authentication sessions after a limited period.
- Security logging: Record suspicious access attempts and incomplete MFA sessions.